

**INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY  
(ICDFA)**

**GRC102: INFORMATION SECURITY GOVERNANCE**

**Week 3 Practical Laboratory**

**Principles of Information Security Governance**

|                            |                                        |
|----------------------------|----------------------------------------|
| <b>Full Name</b>           | <b>MERCY RACHAEL AJAYI</b>             |
| <b>Registration Number</b> | <b>C11/26/CGRCE/17219</b>              |
| <b>Cohort / Batch</b>      | <b>CGRCE Cohort 11</b>                 |
| <b>Course Title</b>        | <b>Information Security Governance</b> |
| <b>Date Submitted</b>      | <b>25th September, 2026</b>            |

## Contents

1. Executive Summary
2. Introduction
3. Evidence Bundle 1 - Task 1: Governance Architecture and Stakeholder Map
4. Evidence Bundle 2 - Task 2: Governance Responsibility and Authority Matrix
5. Evidence Bundle 3 - Task 3: Security Governance Committee Ecosystem
6. Evidence Bundle 4 - Task 4: RACI Accountability Matrix
7. Evidence Bundle 5 - Task 5: Cyber-Risk Escalation Workflow
8. Evidence Bundle 6 - Task 5: Segregation of Duties
9. Conclusion
10. References

## Executive Summary

TechGlobal has about 2,500 staff in five offices and the business is growing, but security decisions are still centred on one person, the IT Director. There is no clear committee, business units act on their own, and the Board and CEO do not get proper reports on cyber risk. In my work as Lead Security Governance Consultant, I looked at these gaps and designed a simple system that can grow with the company.

This report presents a new governance structure that links the Board, the CEO, the CISO, Risk, Legal, Finance, HR, IT and Business Unit Leaders. It explains who owns what, who can approve what, and who must be informed. It also creates three levels of committees, a RACI matrix for 15 key activities, and a three level escalation path from operations to the Board. It closes with a review of segregation of duties problems and how to fix them without adding too much paperwork.

My design follows ideas from ISO/IEC 27014:2020 on governance of information security, COBIT 2019 on roles and RACI, the NIST Cybersecurity Framework (CSF) 2.0 on risk governance, and the Three Lines Model from the Institute of Internal Auditors. I also used the GRC102 Module 3 lesson, which states that "Clear roles are fundamental for effective security governance" and that "Security is a shared responsibility requiring engagement from all stakeholders" (ICDFA, 2026).

## Introduction

From what I learned, security governance is not the same as security operations. Operations is about installing firewalls and monitoring alerts. Governance is about setting direction, making sure security supports business goals, and holding the right people accountable. The lesson note puts it simply: governance "Establishes clear accountability across all organizational levels" and "Ensures security investments support business goals" (ICDFA, 2026).

TechGlobal at the moment practises what the brief calls "security by informal decision". This means decisions depend on personal judgement instead of policy, committees and records. My task in this lab was to:

- Find the weaknesses in the present model and explain what they can cause.
- Draw a clear structure and stakeholder map.
- Write down who is responsible for what and who can approve what.
- Create committees that meet regularly and keep records.
- Build a RACI matrix so accountability is clear during normal work and during incidents.
- Build an escalation workflow and fix segregation of duties problems.

The rest of this report is arranged by Evidence Bundle as requested in Section 9 of the brief, so that each bundle can be checked against Tasks 1 to 5.

# Evidence Bundle 1: Governance Gap Assessment, Stakeholder Map and Organisation Structure

## Task 1: Governance Architecture and Stakeholder Map

### 1.1 Governance Gap Assessment

The current TechGlobal model is mainly IT-centred, with most security decisions going through the IT Director. From the case, I identified six main governance weaknesses. These weaknesses affect how decisions are made, how risks are escalated, and who is accountable for security activities

| No. | Current Weakness                                                                                                                                     | Business or Risk Consequence                                                                                                                                                                                                                                                                                                                        |
|-----|------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1   | Too much security authority is concentrated with the IT Director. He is responsible for security ownership, risk approval and operational decisions. | This reduces independent review and can create conflicts of interest. For example, pressure to deliver systems quickly may affect how security risks are considered. This also creates a single point of failure if the IT Director is unavailable. This is not consistent with the principle of segregation of duties in COBIT 2019 (ISACA, 2019). |
| 2   | There is no formal security governance committee structure. There is no Executive Council, Steering Committee or working group for security matters. | Security, risk, legal, finance and business concerns may not be considered together. This can result in decisions being made mainly from the IT perspective without enough input from other parts of the organisation.                                                                                                                              |
| 3   | Business units make security decisions locally without enough central control.                                                                       | This can lead to different security practices across the five offices. One office may apply a control properly while another may not. It also makes it harder to have consistent reporting and identify organisation-wide security gaps.                                                                                                            |
| 4   | The CEO and Board have limited visibility into cyber risk. There is no clear and regular reporting structure to senior management.                   | Senior management may not have enough information to make decisions about risk appetite, security investment and major cyber risks. ISO/IEC 27014:2020 highlights the role of the governing body in overseeing information security and ensuring that it supports business objectives (ISO, 2020).                                                  |
| 5   | There is no clear risk acceptance and escalation path.                                                                                               | Staff may be unsure when a risk should be escalated or who has the authority to accept it. This can cause serious risks to remain at                                                                                                                                                                                                                |

|   |                                                                                             |                                                                                                                                                                                                                                                                                                                            |
|---|---------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   |                                                                                             | the operational level for too long. It also makes it difficult to track who accepted a risk and the reason for the decision.                                                                                                                                                                                               |
| 6 | Control ownership and accountability are unclear across IT, business and support functions. | When different teams are involved in one control, it may be unclear who is responsible for making sure the whole process works. For example, employee access removal requires coordination between HR, IT and the business. Without clear ownership, access may not be removed on time, creating security and audit risks. |

Overall, the main issue is that security governance at TechGlobal is too informal and too dependent on IT. The organisation needs clearer roles, accountability, escalation paths and involvement from other business functions. These changes would make security decisions more transparent and help TechGlobal manage security as an organisation-wide risk rather than only an IT responsibility.

## 1.2 Stakeholder Map

The stakeholder map shows the main stakeholders involved in TechGlobal's security governance, their level of influence, what they are concerned about, the information they need, and how they contribute to governance.

| Stakeholder        | Authority / Influence | Primary Interest                                                          | Information Needed                                                               | Governance Contribution                                                                |
|--------------------|-----------------------|---------------------------------------------------------------------------|----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| Board of Directors | High                  | Risk appetite, major risks, regulatory exposure, reputation and assurance | Material cyber risks, major incidents, risk trends and assurance results         | Provides oversight, approves direction and challenges management on significant risks. |
| CEO                | High                  | Business growth, strategy, performance and acceptable risk                | Enterprise cyber risks, business impact, major decisions and budget requirements | Provides executive accountability and makes strategic decisions on security and risk.  |
| CISO               | High within security  | Security strategy, policies, risk oversight and                           | Security metrics, risk assessments, incidents, control                           | Leads security governance, develops the                                                |

|                       |                          |                                                                            |                                                                             |                                                                                                            |
|-----------------------|--------------------------|----------------------------------------------------------------------------|-----------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
|                       |                          | programme effectiveness                                                    | performance and business priorities                                         | security programme and reports important issues to management.                                             |
| CRO / Risk            | High for enterprise risk | Risk methodology, risk acceptance, treatment and enterprise risk reporting | Risk register, risk ratings, treatment plans and accepted risks             | Provides an independent risk view and connects cyber risks to the wider enterprise risk framework.         |
| Legal / Compliance    | Medium to high           | Legal requirements, contracts, privacy and regulatory obligations          | Regulatory requirements, incidents, contracts and compliance findings       | Advises on legal and regulatory requirements, including notification and evidence-related decisions.       |
| Finance               | High for funding         | Budget, financial exposure and investment priorities                       | Security business cases, losses, budget requirements and financial impact   | Supports security investment decisions and ensures financial controls are considered.                      |
| Human Resources       | Medium                   | Employee security, awareness, conduct and joiner/mover/leaver processes    | Staff changes, training records, policy violations and workforce risks      | Supports people-related security controls and works with IT and security on employee access and awareness. |
| IT / Technology       | High operationally       | Secure operations, technology delivery and service continuity              | Architecture, vulnerabilities, incidents, system changes and service status | Implements and operates technical controls and provides technical information for security decisions.      |
| Business Unit Leaders | High within their units  | Business operations, local risks and practical control implementation      | Business impact, critical processes, local risks and control status         | Own business risks, implement security requirements and report issues from their units.                    |

### 1.3 Proposed Security Governance Organisation Chart

The proposed structure separates security leadership, risk oversight and technical operations. This reduces the concentration of security decisions within IT and makes responsibilities clearer across the organisation. The structure is designed so that the five offices can follow the same reporting and governance process.

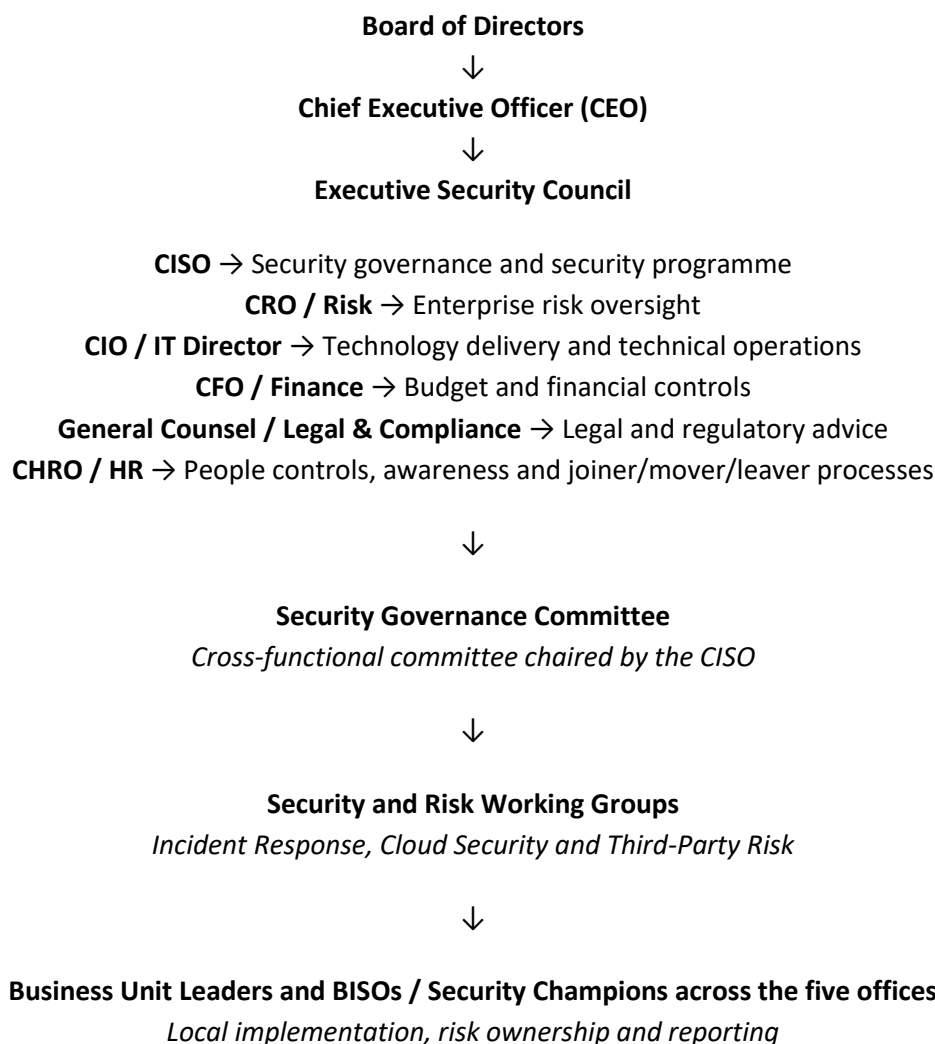


Figure 1: Proposed Security Governance Organisation Chart.

**Reporting and oversight:** The CISO reports to the CEO for day-to-day direction and has a direct oversight relationship with the Board for significant security matters. The CRO reports to the CEO and connects cyber risk with the wider enterprise risk process. The IT Director is responsible for technical implementation and operations, but does not approve the risks created by those activities.

**Communication:** Security issues can move from the business units and IT to the relevant working group, then to the Security Governance Committee and Executive Security Council.

Matters that are significant enough can then be escalated to the Board. Decisions and policies can also move back down through the same structure for implementation.

This structure gives the Board and CEO better visibility while allowing the CISO, CRO, IT, Legal, Finance and HR to contribute from their different areas. IT remains responsible for technology, but security governance is treated as a shared organisational responsibility rather than only an IT responsibility.

## **1.4 Why This Structure Fits TechGlobal**

I consider this structure appropriate for TechGlobal because the organisation is large enough that informal security decisions can create gaps. With about 2,500 employees across five offices, TechGlobal needs consistent security direction while still allowing each business unit to manage its own operational needs. The proposed structure provides central governance without making one person or one department responsible for every security decision.

One of the main reasons for this structure is the separation between security governance, risk and technical implementation. The CISO leads the security programme and policies, the CRO / Risk function provides an enterprise risk perspective, while IT remains responsible for technical implementation and operations. Legal, Finance and HR also contribute from their areas of responsibility. This reduces the concentration of authority identified and makes accountability clearer.

The structure also improves visibility for the CEO and Board. Important security risks can be escalated through the governance structure, while material risks and major incidents can reach senior management. This supports the governance approach in ISO/IEC 27014, which focuses on evaluating, directing, monitoring and communicating information security activities (ISO, 2020). NIST CSF 2.0 also highlights the importance of establishing clear cybersecurity roles, responsibilities and authorities and making leadership accountable for cybersecurity risk (NIST, 2024).

Another reason for the structure is that it can work across all five offices without creating five separate security teams. A central CISO function can set common requirements, while BISOs or Security Champions can help each office apply them in practice and report local issues. This gives the business units a way to raise their concerns while still maintaining consistent security requirements across TechGlobal.

The committee structure also helps replace informal decisions with a clearer process. The Executive Security Council can focus on major strategy and investment decisions, while the Security Governance Committee and working groups can handle cross-functional and more detailed security matters. The aim is not to create unnecessary meetings, but to make sure the right people are involved when decisions need to be made.

Finally, the structure makes control ownership clearer. For example, in access management, HR can initiate joiner, mover and leaver activities, IT can provision or remove access, business

managers can approve access, and the CISO can oversee the related policy and compliance. This reduces the chance of controls being left between departments, which was one of the weaknesses identified in W6.

Overall, the proposed model gives TechGlobal clearer accountability, better risk visibility and more consistent security governance while allowing IT and the business units to continue handling their operational responsibilities.

## Evidence Bundle 2: Governance Responsibility Matrix, Role Profiles and Conflict Resolution

### Task 2: Governance Responsibility and Authority Matrix

#### 2.1 Cross-functional Governance Responsibility Matrix

The matrix below shows the main governance roles, what each role is responsible for, the decisions it can make, where it reports or escalates issues, and the evidence that can be used to measure its performance.

| Role       | Purpose                                                                  | Core Responsibilities                                                                                                 | Decision Authority                                                                                       | Reports / Escalates To                                                                     | KPIs / Evidence                                                                               |
|------------|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|
| Board      | Provide oversight of major cyber and enterprise risks.                   | Approve risk appetite, review material cyber risks, major incidents and assurance results.                            | Approves risk appetite and material risk decisions within Board authority.                               | Receives reports from the CEO and relevant Board committees.                               | Quarterly cyber-risk reviews; percentage of material risks within appetite.                   |
| CEO        | Provide executive accountability and align security with business goals. | Set strategic direction, resolve major cross-functional issues and ensure the right resources are available.          | Approves major security and business decisions within executive authority.                               | Reports to the Board and escalates material risks when necessary.                          | Timeliness of major risk decisions; security investment decisions.                            |
| CISO       | Lead enterprise security governance and the security programme.          | Develop security strategy and policies, oversee controls, manage security reporting and coordinate governance forums. | Makes security decisions within delegated authority and recommends major security actions to management. | Reports to the CEO and escalates material security risks through the governance structure. | Security policy review completion; risk treatment closure rate; major incident reporting time |
| CRO / Risk | Connect cyber risk                                                       | Maintain the                                                                                                          | Provides                                                                                                 | Reports                                                                                    | Percentage of risks with an                                                                   |

|                    |                                                               |                                                                                                                                    |                                                                                                  |                                                                                                           |                                                                                                  |
|--------------------|---------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
|                    | with the wider enterprise risk process.                       | risk methodology, challenge risk assessments, oversee risk acceptance and track risk treatment                                     | independent risk challenge and advises on risk acceptance.                                       | through the enterprise risk structure and escalates significant risks to executive and Board risk forums. | owner and treatment date; overdue risk treatments; accepted risks reviewed.                      |
| Legal / Compliance | Provide legal and regulatory guidance for security decisions. | Interpret legal requirements, review contracts and privacy obligations, and advise on evidence and notification requirements.      | Advises and approves legal positions within its authority.                                       | Escalates significant legal or regulatory issues to the CEO or Board where necessary.                     | Regulatory obligations tracked; notification decisions documented; contract compliance coverage. |
| Finance            | Support sound financial governance for security activities.   | Review security budgets, investment cases, financial losses and related controls.                                                  | Approves funding within delegated financial authority.                                           | Reports through Finance leadership and the executive governance structure.                                | Budget variance; investment cases reviewed; financial loss exposure reporting.                   |
| HR                 | Manage people-related security controls.                      | Manage joiner, mover and leaver processes, security awareness, conduct and disciplinary matters.                                   | Makes HR decisions within its authority and approves HR processes and actions.                   | Escalates significant people-related issues through HR and the appropriate governance channels.           | Timely access removal for leavers; training completion; leaver control compliance.               |
| IT                 | Implement and operate secure technology controls.             | Manage secure operations, technical implementation, vulnerability remediation, service continuity and technical incident response. | Makes technical implementation decisions within approved policies, architecture and risk limits. | Reports operational security issues to the CISO and relevant governance committees.                       | Critical vulnerabilities remediated on time; control uptime; incident response performance.      |

## 2.2 Role Profiles / Responsibility Cards

- **Board of Directors**

The Board provides oversight of major cyber and enterprise risks rather than managing daily security operations. Its main responsibilities are to approve the risk appetite and security strategy, review material risks and major incidents, and make sure management is addressing significant security issues. The Board also holds the CEO accountable for material risks and receives regular security and assurance reports.

**Decision authority:** Approves risk appetite, strategy, major security budgets and material risk acceptance within its authority.

**Reports / escalation:** Receives quarterly reports from the CEO and CISO, with immediate escalation of material incidents or risks.

**Performance indicators:** Quarterly risk reviews completed and material risks reviewed within agreed timelines.

- **CEO**

The CEO provides executive accountability for security and makes sure security decisions support business objectives. The CEO chairs the Executive Security Council, resolves major issues between functions and ensures that the organisation has the resources needed to manage security risks. Material risks and incidents are escalated to the Board when necessary.

**Decision authority:** Approves major security decisions, high-risk acceptance and significant investments within the authority given by the Board.

**Reports / escalation:** Reports to the Board and receives escalated issues from the CISO, CRO, IT and other functions.

**Performance indicators:** Timely resolution of major risk decisions and delivery of agreed security programme milestones.

- **CISO**

The CISO leads security governance across TechGlobal's five offices. The course material describes the CISO as the senior executive responsible for the organisation's security vision, strategy and programme. [Course Material, p. 6] The CISO develops security policies and standards, monitors controls and risk treatment, coordinates governance committees and provides security information to management.

**Decision authority:** Makes security decisions within delegated authority and recommends major security and risk decisions to the CEO and Board.

**Reports / escalation:** Reports to the CEO and escalates material security risks and incidents through the governance structure.

**Performance indicators:** High-risk findings remediated within agreed timelines and overdue risk acceptances monitored.

- **CRO / Risk**

The CRO / Risk function connects cyber risk with TechGlobal's wider enterprise risk process. It maintains the risk methodology, challenges risk assessments, reviews treatment plans and helps management understand how cyber risks fit with other business risks. The role provides an independent risk perspective but does not take over technical control ownership.

**Decision authority:** Provides risk challenge and advises on risk acceptance within the approved risk framework.

**Reports / escalation:** Reports through the enterprise risk structure and escalates significant risks to executive and Board risk forums.

**Performance indicators:** Risks with assigned owners and treatment dates, and the percentage of risk treatments completed on time.

- **Legal / Compliance**

Legal / Compliance helps TechGlobal understand and meet its legal and regulatory obligations. This includes privacy requirements, contracts, security clauses, evidence handling and incident notification. The function should be involved when a security issue could create legal or regulatory consequences.

**Decision authority:** Provides legal advice and approves legal positions within its authority, including regulatory notification requirements.

**Reports / escalation:** Escalates significant legal and regulatory issues to the CEO and Board where appropriate.

**Performance indicators:** Regulatory obligations tracked and required notifications completed within the applicable deadlines.

- **Finance**

Finance supports the financial side of security governance. It reviews security budgets and investment proposals, monitors spending and helps assess the financial impact of security incidents and risks. Finance does not determine whether a technical control is secure, but it helps management understand the cost and financial exposure involved.

**Decision authority:** Approves security spending within delegated financial authority.

**Reports / escalation:** Reports financial information through Finance leadership and the executive governance structure.

**Performance indicators:** Budget variance and security investment cases reviewed.

- **Human Resources**

HR manages the people-related parts of security governance. This includes joiner, mover and leaver processes, security awareness, employee conduct and disciplinary matters. HR works with IT and the CISO to make sure employee-related controls are properly carried out.

**Decision authority:** Makes HR decisions within its authority and approves relevant workforce processes.

**Reports / escalation:** Escalates significant employee, insider or conduct issues through HR and the appropriate security or legal channels.

**Performance indicators:** Timely removal of leaver access, staff security awareness completion and compliance with leaver controls.

- **IT / Technology**

IT is responsible for implementing and operating the technical controls required by TechGlobal. This includes system operations, patching, vulnerability remediation, backups, logging, technical incident response and service continuity. IT works within approved security policies, architecture and risk limits rather than owning the entire security governance process.

**Decision authority:** Makes technical implementation decisions within approved architecture, policies and risk limits. It does not approve its own risk acceptance or policy exceptions.

**Reports/escalation:** Reports operational security information to the CISO and relevant governance committees and escalates serious control failures.

**Performance indicators:** Critical vulnerabilities remediated within agreed timelines, system control availability and incident response performance.

## 2.3 Areas of Authority Overlap and Conflict Resolution

Some areas of responsibility may overlap because different roles are involved in the same security decision. The important thing is to make it clear who has the final authority and how disagreements should be handled.

| Potential conflict                       | Why it could happen                                                                                                                                                                                                                     | Resolution                                                                                                                                                                                                                                                                                                                                                       |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CISO vs IT on security architecture      | The CISO is responsible for security requirements, while IT is responsible for choosing and implementing technology. This can create disagreement when IT wants a solution that is faster or cheaper but the CISO has security concerns | The CISO sets the security requirements and architecture principles, while IT designs and implements the solution within those requirements. If there is a disagreement, it is taken to the Security Governance Committee for review. Major exceptions are documented and escalated to the CEO when necessary.                                                   |
| CISO vs CRO / Risk on risk acceptance    | The CISO understands the technical security issue and may consider the risk high, while the CRO / Risk function looks at the risk from the wider business perspective.                                                                  | The CISO provides the security assessment and treatment recommendation, while CRO / Risk provides independent challenge. If they disagree on the rating or treatment, both views are presented to the appropriate governance forum. High or material risks are accepted by the authorised executive or Board, rather than by the person who identified the risk. |
| CEO vs Board on major risk decisions     | The CEO is responsible for managing the organisation, while the Board provides oversight and sets the organisation's risk appetite. This can create overlap when a security risk is significant.                                        | The CEO handles decisions within the authority delegated by the Board. Risks that are above the agreed materiality or risk appetite threshold are escalated to the Board for review and decision.                                                                                                                                                                |
| Legal vs CISO on regulatory notification | During a security incident, the CISO may focus on quickly understanding and containing the incident, while Legal must consider legal and regulatory notification requirements.                                                          | The CISO provides the verified incident facts and impact assessment. Legal advises on notification requirements and deadlines. The authorised executive makes the final decision and the reason is recorded.                                                                                                                                                     |

**General principle:** For any conflict, there should be one clearly identified person accountable for the final decision. The person implementing a control should not be the same person approving their own work. Where necessary, Risk, Legal or the CISO should be able to challenge or escalate a decision. Important disagreements and final decisions should also be recorded in the decision log so there is a clear record of what was decided and why.

## Evidence Bundle 3: Security Governance Committee Ecosystem

### Task 3: Security Governance Committee Ecosystem

#### 3.1 Committee Ecosystem Design

I designed the committee structure in three layers so that routine security matters can be handled at the appropriate level, while more serious issues are escalated to senior management. This helps avoid taking every security decision to the CEO or Board and still gives senior management proper visibility.

##### A. Executive Security Council

The Executive Security Council provides strategic oversight of security across TechGlobal. It is chaired by the CEO and includes the CISO, CRO / Risk, CFO, General Counsel, CHRO, CIO / IT Director and one rotating Business Unit Leader. The CISO office acts as secretary.

The Council meets quarterly, with an emergency meeting within 48 hours where there is a material security incident or urgent risk. Its main responsibilities are to review security strategy, risk appetite, major security investments, material risks, major incidents and overall programme progress.

**Authority:** The Council can approve high risks within its authority, direct security funding and priorities, and escalate material matters to the Board.

##### B. Security Governance / Steering Committee

The Security Governance Committee is the main cross-functional governance forum. It is chaired by the CISO, with the CRO / Risk as deputy. Members include IT, Legal / Compliance, Finance, HR, Risk and rotating representatives from the five business offices. Internal Audit can attend as an observer where available.

The committee meets monthly and focuses on matters that need coordination across different functions. These include the risk register, policy changes, third-party security, vulnerabilities, audit findings, security exceptions and remediation plans. It also prepares important issues for the Executive Security Council and Board.

**Authority:** The committee can approve moderate risks, policy details, remediation plans and temporary exceptions within its delegated authority. High and material risks are escalated to the Executive Security Council, CEO or Board as appropriate.

##### C. Specialised Working Group: Incident Response Working Group

I selected the Incident Response Working Group because incident handling is one area where clear escalation is especially important. The group is chaired by the SOC / Incident Response

Lead under the CISO and includes IT Operations, Helpdesk, a BISO or Security Champion, HR for insider-related cases, Legal and Communications when required.

The group has a short weekly meeting and conducts a tabletop exercise each quarter. Its main role is to review security events, support incident response playbooks, track lessons learned and recommend improvements.

**Authority:** The group can handle low-level incidents according to approved playbooks. More serious incidents are escalated through the defined incident response process.

### **Business Unit Participation**

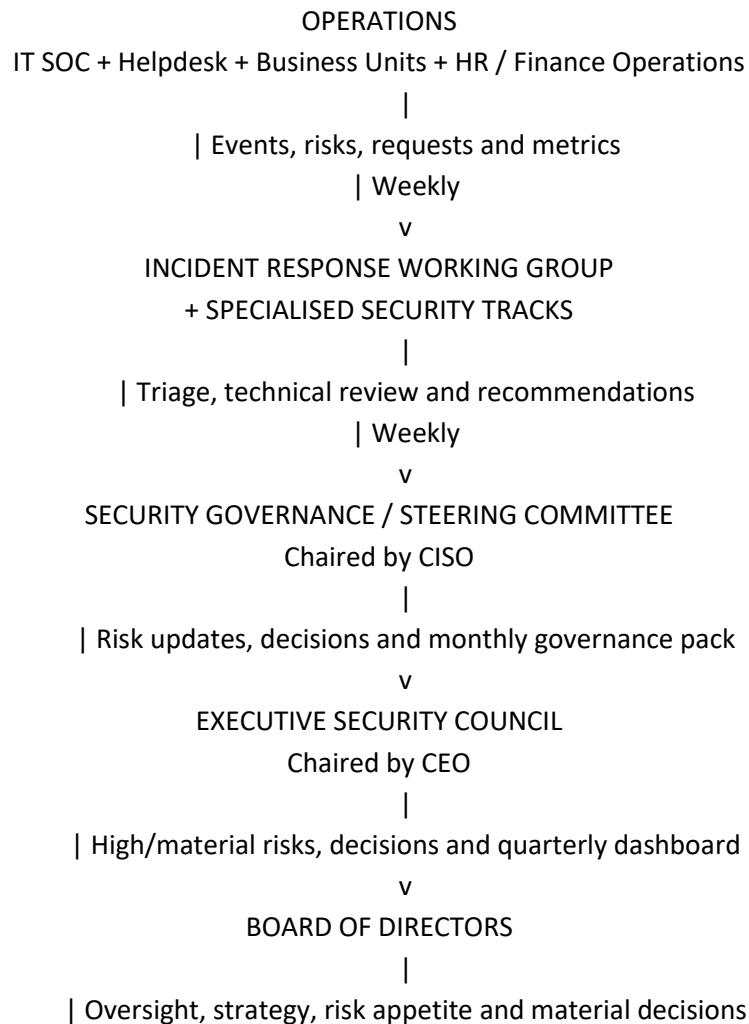
The five offices should have a nominated BISO or Security Champion who understands the local business processes and acts as the link between the business unit and central security. The champions can help communicate policies and training, raise local risks, support access reviews and participate in incident exercises.

Business units can manage their operational security needs, but they must work within the central security requirements. Any exception to those requirements must go through the appropriate governance process and have a clear review date.

This approach gives the business units a voice without creating separate security structures. It also supports the course material, which describes security champions as security advocates within departments and BISOs as a link between central security and the business.

### 3.2 Committee Structure / Interaction Diagram

The committee structure shows how security information and decisions move from day-to-day operations to senior management and the Board.



#### Downward flow:



Figure 2: Security Governance Committee Interaction and Decision Flow

The downward flow is used to communicate approved policies, priorities, funding decisions and actions that need to be implemented.

### **Information and Decision Flow**

Operational teams identify issues and provide the relevant evidence. Working groups review these issues and prepare recommendations for the Security Governance Committee. The committee handles cross-functional matters and escalates high or material risks to the Executive Security Council. The Council deals with major strategic and executive decisions, while matters requiring Board oversight are escalated further.

Information also moves back down the structure. Decisions made by the Board, Council or Steering Committee are communicated to the teams responsible for implementation. This helps make sure that governance decisions are actually carried out at the operational level.

For reporting, working groups provide updates and risk changes to the Steering Committee each month. The Steering Committee then provides a dashboard and important decision requests to the Executive Security Council. The Council provides the Board with information on major risks, incidents, security spending and assurance matters.

For a serious incident, the normal reporting sequence can be shortened. The Incident Response Working Group can escalate directly to the CISO, who can escalate to the CEO, and the CEO can brief the Board Chair where the incident is material. This allows urgent issues to be handled quickly without waiting for the next scheduled committee meeting.

### 3.3 Terms of Reference for the Security Governance Committee

**Document control:** Version 1.0

**Owner:** CISO

**Approved by:** CEO on behalf of the Executive Security Council

**Review:** Annual

#### 1. Purpose

The Security Governance Committee provides a regular cross-functional forum for reviewing security risks, policies, compliance matters and technology-related security decisions. It also helps ensure that security requirements are applied consistently across TechGlobal's five offices.

#### 2. Scope

The committee reviews the security risk register, policy changes, third-party security, vulnerabilities, audit findings, security awareness results, exception requests and lessons from security incidents.

Day-to-day IT tickets and operational tasks are outside its scope. Enterprise strategy, risk appetite and Board-level decisions are handled by the Executive Security Council or Board.

#### 3. Membership and Quorum

The **CISO** is the Chair and the **CRO / Risk** is the Deputy Chair. Core members include representatives from IT, Legal / Compliance, Finance, HR and two rotating BISOs from the business offices.

Internal Audit may attend as an observer without voting rights. System owners or other subject matter experts can also be invited when their input is needed.

A quorum requires the Chair or Deputy Chair, at least four other members, one BISO and either Legal or Finance.

#### 4. Meetings and Administration

The committee meets monthly for 90 minutes, with additional meetings when urgent security matters require attention.

Meeting papers should be circulated at least five business days before the meeting. Minutes, decisions and action points should be recorded and shared within five business days after the meeting. The CISO office provides the secretariat.

## **5. Responsibilities**

The committee is responsible for:

- Reviewing and challenging security risk assessments and treatment plans.
- Reviewing and approving security policy details within its authority.
- Reviewing third-party and cloud security risks.
- Tracking vulnerability, audit and incident actions until closure.
- Reviewing security KPIs and awareness results.
- Reviewing security exceptions and remediation plans.
- Preparing important issues and reports for the Executive Security Council and Board.

## **6. Decision Authority**

The committee can approve moderate risk acceptance, policy details, remediation priorities and temporary exceptions of up to 90 days within its delegated authority.

It cannot approve high or material risk acceptance, the annual security budget or enterprise security strategy. These matters are escalated with a written recommendation and supporting rationale.

## **7. Reporting and Escalation**

The committee receives regular updates from the relevant working groups and reports to the Executive Security Council quarterly.

Its reporting pack should include the security dashboard, important decisions, outstanding actions and matters requiring executive attention. Material risks, unresolved conflicts and decisions outside the committee's authority are escalated through the defined governance structure.

## **8. Conduct and Conflicts of Interest**

Members must declare any conflict of interest at the beginning of a meeting. The maker and checker should be different people, so that a person does not approve their own work.

Where members disagree, the different views should be recorded rather than removed from the minutes. Decisions are made by majority vote, with the Chair having a casting vote where there is a tie. Issues that cannot be resolved at committee level should be escalated to the CEO within 10 business days.

## **9. Records and Review**

The committee should maintain its agendas, attendance records, decisions, decision rationale, action owners, due dates and review dates.

The Terms of Reference should be reviewed annually and after a material security incident or major organisational change. The effectiveness of the committee should also be reviewed through an annual member survey.

### 3.4 Sample Committee Agenda

#### Security Governance Committee

**Date:** 12 November 2026

**Time:** 10:00 to 11:30 WAT

**Chair:** CISO

| Time           | Agenda Item                                                                                                   | Lead           | Expected Outcome                                            |
|----------------|---------------------------------------------------------------------------------------------------------------|----------------|-------------------------------------------------------------|
| 10:00 to 10:05 | Welcome, attendance and declaration of conflicts                                                              | Chair          | Record attendance and any conflicts of interest             |
| 10:05 to 10:15 | Review of previous minutes and outstanding actions                                                            | Secretariat    | Approve minutes and review the 8 open actions               |
| 10:15 to 10:30 | Security risk register: 3 new risks and 2 overdue treatments, including the Lagos office patching delay       | CRO / CISO     | Decide whether to accept, extend or escalate the risks      |
| 10:30 to 10:45 | Access Control Policy v2 and a 90-day exception request for the Sales tool                                    | CISO / HR      | Approve the policy and decide on the exception request      |
| 10:45 to 11:00 | Third-party security review of the Cloud CRM vendor, including weak SSO and lack of audit logging             | IT / Legal     | Decide on conditional use and required security controls    |
| 11:00 to 11:15 | October vulnerability and incident metrics, phishing test results and Incident Response Working Group lessons | IRWG Lead      | Agree on remediation owners and target dates                |
| 11:15 to 11:25 | Escalations to the Executive Security Council: MFA rollout funding and high risk from the legacy ERP          | CISO / Finance | Agree on the recommendation and information to be escalated |
| 11:25 to 11:30 | Any other business and next meeting                                                                           | Chair          | Confirm final actions and next meeting date                 |

### 3.5 Sample Decision Log

The decision log records important governance decisions, who made them, why they were made, the actions that follow, and when the decision should be reviewed. The CISO office maintains the full log and reviews it monthly.

| Date        | Decision / Issue                                                                   | Decision Owner                | Decision / Rationale                                                                              | Action / Owner                                                              | Review Date |
|-------------|------------------------------------------------------------------------------------|-------------------------------|---------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|-------------|
| 21 Sep 2026 | High-risk supplier requires an additional security review before contract renewal. | Security Governance Committee | The supplier handles sensitive information and the available security evidence is incomplete.     | Procurement and Security to complete the review.                            | 21 Oct 2026 |
| 21 Sep 2026 | Critical vulnerability remediation deadline reduced for internet-facing systems.   | CISO                          | The affected systems are externally accessible, which increases the potential exposure.           | IT to complete remediation and provide evidence.                            | 5 Oct 2026  |
| 21 Sep 2026 | Material cyber risk requires executive approval before acceptance.                 | Executive Security Council    | The risk is above the level that operational management can accept under the delegated authority. | CRO / Risk to update the risk register and route the decision for approval. | 30 Sep 2026 |

### 3.6 Twelve-Month Governance Calendar

The calendar below shows the main security governance activities planned from October 2026 to September 2027. It shows when the main committees meet, the key activities for each period, who is responsible and what should be produced. Emergency meetings can be added when a serious security issue needs urgent attention.

| Month         | Governance Activity                                                                                        | Forum                                           | Owner          | Expected Output                              |
|---------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------|----------------|----------------------------------------------|
| October 2026  | Approve the Terms of Reference and RACI v1, and begin cleaning up the security risk register.              | Steering Committee + Executive Security Council | CISO           | Approved ToR, RACI and assigned risk owners  |
| November 2026 | Monthly risk and policy review, including the first incident response tabletop exercise.                   | Steering Committee + IRWG                       | CISO / IR Lead | Meeting minutes and tabletop exercise report |
| December 2026 | Review the security strategy and budget draft and prepare the Board reporting pack.                        | Executive Security Council                      | CEO / CISO     | Board paper and budget request               |
| January 2027  | Approve the annual security strategy and risk appetite, and begin the annual security awareness programme. | Board / Executive Security Council              | Board / CEO    | Approved strategy and training plan          |
| February 2027 | Complete the first batch of third-party security reviews and carry out access recertification.             | Steering Committee                              | CISO / HR / IT | Supplier review reports and access sign-off  |

|                |                                                                                                                                 |                                     |                              |                                                               |
|----------------|---------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|------------------------------|---------------------------------------------------------------|
| March 2027     | Q1 security and risk update, including approval of the penetration testing scope.                                               | Executive Security Council + Board  | CISO                         | Q1 dashboard and approved test scope                          |
| April 2027     | Review security policies and conduct a business continuity exercise for selected offices.                                       | Steering Committee + Business Units | CISO / Business Unit Leaders | Updated policies and exercise findings                        |
| May 2027       | Review security activities, conduct the second incident response tabletop exercise and complete the second vendor review batch. | Steering Committee + IRWG           | IR Lead / CISO               | Updated incident response playbooks and vendor review reports |
| June 2027      | Q2 security and risk update and mid-year review of the security budget and programme.                                           | Executive Security Council + Board  | CEO / CFO / CISO             | Mid-year assurance report                                     |
| July 2027      | Carry out a detailed vulnerability management and cloud security review.                                                        | Steering Committee                  | IT / CISO                    | Vulnerability remediation and cloud security plans            |
| August 2027    | Review security awareness results and conduct a phishing retest.                                                                | Steering Committee                  | HR / CISO                    | Training and phishing test metrics                            |
| September 2027 | Q3 security and risk update and annual review of committee effectiveness.                                                       | Executive Security Council + Board  | CEO / CISO                   | Annual governance report and improvement plan                 |

## Evidence Bundle 4: RACI Accountability Matrix

### Task 4: Governance Responsibility and Authority Matrix

#### 4.1 Completed TechGlobal RACI Matrix

RACI helps show who is responsible for doing the work and who is accountable for the final outcome. **R** means Responsible, **A** means Accountable, **C** means Consulted, and **I** means Informed. Each activity should have one clear accountable role, while other roles can be responsible, consulted or informed depending on the activity.

| Activity                                  | Board | CEO | CISO | CRO/Risk | Legal | Finance | HR | IT | BU Leader |
|-------------------------------------------|-------|-----|------|----------|-------|---------|----|----|-----------|
| Cybersecurity strategy approval           | A     | C   | R    | C        | C     | C       | I  | C  | C         |
| Security policy approval                  | I     | I   | A    | C        | C     | I       | C  | R  | C         |
| Enterprise cyber-risk assessment          | I     | I   | R    | A        | C     | C       | C  | R  | C         |
| Risk acceptance                           | A     | R   | C    | R        | C     | C       | I  | I  | C         |
| Security budget approval                  | A     | R   | R    | C        | I     | R       | I  | C  | C         |
| Security architecture approval            | I     | C   | A    | C        | I     | C       | I  | R  | C         |
| Third-party security review               | I     | I   | A    | C        | C     | C       | I  | R  | C         |
| Access governance                         | I     | I   | A    | I        | C     | C       | R  | R  | C         |
| Incident response governance              | I     | C   | A    | C        | C     | I       | C  | R  | C         |
| Material incident escalation              | I     | A   | R    | C        | C     | I       | I  | C  | I         |
| Regulatory notification decision          | I     | A   | C    | C        | R     | I       | I  | C  | I         |
| Security awareness programme              | I     | I   | A    | I        | C     | I       | R  | C  | C         |
| Vulnerability remediation Oversight       | I     | I   | A    | C        | I     | I       | I  | R  | R         |
| Business continuity / recovery governance | I     | A   | C    | R        | C     | C       | C  | R  | R         |
| Board cyber-risk reporting                | I     | C   | R    | A        | C     | C       | I  | C  | I         |

## **RACI Key**

- **R = Responsible:** Does the work.
- **A = Accountable:** Owns the final outcome.
- **C = Consulted:** Provides input before the activity or decision.
- **I = Informed:** Receives the relevant information after or during the activity.
- **A/R = Accountable and Responsible:** The same role both carries out and owns a small central task.

## 4.2 Three Problematic RACI Assignments

| Issue                                                                                                                         | Why it could be a problem                                                                                                                                                             | How to manage it                                                                                                                                                                                                                                                        |
|-------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk acceptance has different accountable authorities depending on the risk level.                                            | If the approval level is not clear, staff may not know who has the final authority to accept a risk. This can lead to delays or risks being accepted by the wrong person.             | Use clear risk thresholds and delegated authority. The CRO / Risk function is accountable for moderate risks within its authority, while high or material risks are escalated to the CEO or Board as required.                                                          |
| IT is Responsible for security architecture implementation, while the CISO is Accountable for security architecture approval. | IT understands the technical environment and carries out the implementation, but allowing the same function to approve its own security decisions could reduce independent challenge. | Keep the CISO as <b>A</b> for security architecture approval and IT as <b>R</b> for implementation. IT can provide the technical input needed, while the CISO checks that the solution meets the required security standards.                                           |
| Incident response involves several roles.                                                                                     | During a security incident, too many people making decisions can slow down the response or create confusion about who should act.                                                     | Keep the CISO as <b>A</b> for incident response governance and IT as <b>R</b> for the technical response. Legal is consulted when there are legal or regulatory concerns, while serious incidents are escalated to the CEO or Board based on the materiality threshold. |

## 4.3 One-Page RACI Implementation Guide

**Purpose:** This guide helps TechGlobal managers use the RACI matrix during planning, approvals and security incidents. Managers should check the RACI before starting an activity so that everyone knows their role from the beginning.

### 1. During Planning

For a new project, tool or vendor, find the relevant activity in the RACI matrix.

- **R:** You are responsible for doing the work and providing the required evidence.
- **A:** You are accountable for the final outcome and must make sure the work is completed properly.
- **C:** You should be consulted before the decision or work is completed.
- **I:** You need to be informed of the outcome but do not need to be involved in every discussion.

For example, when introducing a new SaaS tool, IT can be **R** for the technical review, the CISO can be **A**, while Legal and the Business Unit are **C**. The purchase should not proceed until the required consultation and approval have been completed.

### 2. During Approvals and Exceptions

Only the person marked **A** can give the formal approval. A recommendation or email from someone marked **R** or **C** does not replace the required approval.

Managers should use the correct form for the decision, such as the risk acceptance, exception or architecture review form. The relevant RACI row should also be referenced so that the approval authority is clear.

If the accountable person is unavailable, the documented deputy or delegated authority should be used. Managers should not assume that someone else can approve simply because they are senior.

### 3. During Security Incidents

For incidents, managers should use the relevant RACI rows together with the incident escalation procedure. IT is **R** for technical response and containment, while the CISO is **A** for incident response governance. Legal should be involved where legal or regulatory requirements apply.

Serious incidents should not wait for the next committee meeting. They should follow the required escalation timeframe based on their severity. Actions, decisions, owners and times should be recorded during the incident.

After the incident, the Incident Response Working Group should review whether the RACI was followed and identify any changes needed to the response process.

#### **4. Common Mistakes to Avoid**

Managers should avoid the following:

- Treating an **I** role as if it was consulted.
- Giving an activity more than one **A**.
- Skipping a required **C** just to save time.
- Treating silence as approval.
- Assuming that the most technical person is automatically accountable.

If there is uncertainty about who should approve or own an activity, managers should check the RACI matrix and use the governance structure to clarify it.

#### **5. RACI Review and Updates**

The RACI should be reviewed every six months by the Security Governance Committee and whenever there is a major organisational change or material security incident.

Changes should go through the agreed governance process, including CISO review, CRO / Risk review, Steering Committee recommendation and Executive Security Council approval. The version number and date should be shown on every approved copy.

This approach helps TechGlobal keep responsibilities clear and supports the NIST CSF 2.0 principle that cybersecurity roles, responsibilities and authorities should be established, communicated and enforced.

## **Evidence Bundle 5: Cyber-Risk Escalation Workflow**

### **Task 5: Cyber-Risk Escalation**

#### **5.1 Major Cyber-Risk Escalation Workflow**

This workflow shows how TechGlobal should handle a major cyber risk from the time it is identified until the issue is treated and formally closed. It can be used for live incidents as well as risks identified through audits, vulnerabilities, vendors or other security activities.

##### **Step 1: Detect or Identify**

The issue can be identified by the SOC, IT, Business Unit or Audit.

- Record the issue in the ticketing system and risk register.
- Include the time, affected asset, available evidence and initial view of the impact.
- Notify the line manager and Incident Response Working Group (IRWG) within 1 hour.

##### **Step 2: Triage and Score**

The IRWG Lead and Risk Analyst review the issue and confirm the facts.

- Incidents should be assessed within 4 hours, while newly identified risks should be assessed within 2 working days.
- Assess the likelihood and impact using the approved CRO / Risk scoring method.
- Assign the appropriate level: L1, L2 or L3.
- L1 issues are handled under the relevant playbook and tracked until closure.

##### **Step 3: Assess and Recommend**

For L2 and L3 issues, the CISO office works with IT and other relevant functions such as Legal, HR or the Business Unit.

The escalation pack should contain:

- What happened and the available evidence
- Business and security impact
- Available treatment options
- Estimated cost
- Required decision and deadline

CRO / Risk reviews the risk assessment, while Legal reviews L3 issues where legal or regulatory concerns may apply.

#### **Step 4: Make the Decision**

The decision is made according to the escalation level and delegated authority.

- **L2:** The CISO makes the recommendation and the CEO makes the decision within 5 business days, or within 24 hours for an active incident.
- **L3:** The CEO and CISO make the recommendation and the Board makes the final decision. An emergency meeting can be called when necessary.

The decision, owner, reason for the decision and review date must be recorded in the decision log.

#### **Step 5: Act and Communicate**

The assigned owner carries out the agreed treatment or containment action.

Legal handles any required regulatory notifications, while Finance tracks relevant financial costs. Communication is handled according to the approved communication plan.

#### **Step 6: Track and Close**

The CISO office tracks the action until the agreed deadline and checks that evidence of completion has been provided.

CRO / Risk confirms closure or approves an extension where necessary. Any extension should have a new approval and review date.

Lessons learned are shared with the IRWG and Security Governance Committee. Where necessary, the RACI matrix, procedures or incident playbooks are updated.

**Entry point:** A detected or identified issue with a recorded ticket or risk register entry.

**Exit point:** A recorded decision, completed treatment or containment, supporting evidence and formal closure in the risk register.

An issue can move directly to a higher level if triage shows that the impact is material. For example, customer data theft, ransomware affecting a critical system or significant regulatory involvement may require immediate L3 escalation. In such cases, the CISO and CEO should be notified without waiting for the normal committee meeting.

## 5.2 Escalation Threshold Table

The escalation level is based on the impact, scope and urgency of the issue, not only its technical severity. Where personal data, safety or regulatory concerns are involved, the issue should be treated more seriously until the facts are confirmed.

| Level                     | Example Trigger                                                                                                                                                                                                                                              | Decision Authority                                                                                                                   | Required Notification                                                                                                                                | Target Response Time                                                                                                                                                 |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Level 1: Operational      | A contained malware infection on one laptop, a low-risk vulnerability on a non-critical system, a failed phishing attempt affecting a few users, or a minor policy breach with no data loss.                                                                 | Operational manager / IT, with CISO oversight. Moderate risks follow the CRO / Risk process.                                         | Line manager, IRWG and affected Business Unit or BISO. Included in the monthly Steering Committee summary.                                           | Acknowledge within 4 hours, contain within 1 business day and close within 10 business days.                                                                         |
| Level 2: Executive        | Ransomware affecting one office, a critical vulnerability such as CVSS 9+ on an internet-facing system, a vendor breach affecting TechGlobal data, repeated control failure, a high-risk acceptance request or an incident with possible legal requirements. | CEO based on CISO and CRO / Risk recommendation. The Steering Committee reviews where time allows.                                   | CISO, CRO / Risk, Legal, Finance, HR where relevant, affected Business Unit Leaders and the Executive Security Council. CEO is briefed the same day. | Triage within 4 hours, escalation pack within 24 hours and CEO decision within 5 business days. For an active incident, the decision should be made within 24 hours. |
| Level 3: Material / Board | Major customer data theft, core service outage lasting more than 4 hours, active extortion, regulator or major media enquiry, a loss expected to exceed the approved risk                                                                                    | Board, based on recommendations from the CEO, CISO and Legal. The CEO can authorise emergency containment before the Board decision. | Board Chair, Board, CEO, CISO, CRO / Risk, Legal, Finance and affected Business Unit Leaders. Regulators or customers are notified where required.   | Immediate notification to the CISO and CEO, normally within 1 hour. Board briefing within 24 hours and regulatory notification according to the applicable legal     |

|  |                                                                 |  |  |           |
|--|-----------------------------------------------------------------|--|--|-----------|
|  | appetite, or a critical supplier breach with widespread impact. |  |  | deadline. |
|--|-----------------------------------------------------------------|--|--|-----------|

**Note:** The financial threshold is only a guide and should be confirmed when the Board sets the organisation's risk appetite. An issue can also move directly from one level to another if new information shows that its impact is more serious than first assessed.

## Evidence Bundle 6: Segregation of Duties

### Task 6: Segregation-of-Duties / Accountability Weakness Register

#### 6.1 Segregation-of-Duties / Accountability Weakness Register

I focused on areas where one person or department could have too much control over the same activity. The controls below are meant to separate key duties without creating unnecessary bureaucracy.

| ID | Weakness / Conflict                                                                              | Risk Created                                                                                                              | Roles Involved                  | Recommended Control                                                                                                                                                                                                                          | Residual Risk / Review                                                               |
|----|--------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| S1 | IT designs the security architecture, implements changes and also approves the go-live decision. | Changes could be approved without enough independent review, increasing the chance of security gaps and audit findings.   | IT/CISO                         | IT proposes and implements the change, while the CISO approves the security architecture. Major changes go through the change board. Emergency changes must receive retrospective approval within 2 days and all approvals must be recorded. | Low if approvals are properly recorded. Steering Committee reviews a sample monthly. |
| S2 | IT operates the systems and also handles the main monitoring of security alerts.                 | An operational issue could be overlooked or downgraded because the same team is responsible for the system's performance. | IT, CISO                        | Security monitoring governance should sit with the CISO through the SOC / IRWG. IT provides system logs and technical support but should not close significant security alerts without review.                                               | Low to medium until monitoring is sufficiently independent. Review quarterly.        |
| S3 | IT assesses cyber risks and may also accept risks affecting systems it owns.                     | IT may accept a risk to avoid additional cost or delays, without enough independent challenge.                            | IT, BU Leader, CISO, CRO / Risk | IT and CISO assess the risk, the Business Unit proposes acceptance where appropriate, and CRO / Risk provides independent challenge. CEO or Board accepts high or material risks according to the risk level. No self-acceptance of risks    | Low when the risk form and register are properly used. CRO / Risk reviews monthly.   |

|    |                                                                                                        |                                                                                                                             |                                     |                                                                                                                                                                                                                                                                                                |                                                                                  |
|----|--------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|
|    |                                                                                                        |                                                                                                                             |                                     | above low level.                                                                                                                                                                                                                                                                               |                                                                                  |
| S4 | IT provisions user access and also reviews that access, while HR notifications may be informal.        | Excessive access or access belonging to former employees may remain active, creating security and audit risks.              | IT, HR, BU Leader, CISO             | HR starts the joiner, mover and leaver process, IT manages the technical access, and the Business Unit manager reviews access regularly. The CISO monitors the access control KPI. Where possible, access should be automatically disabled within 24 hours of the recorded exit time.          | Low if the process is automated and monitored. Quarterly access recertification. |
| S5 | Business Unit Leaders can approve local security exceptions without a central record or expiry date.   | Different security standards may develop across the business, creating unmanaged risks and reducing central visibility.     | BU Leaders, CISO, IT                | All security exceptions should be recorded and approved through the Security Governance Committee. Exceptions should normally last no more than 90 days and include compensating controls and a review date.                                                                                   | Low to medium during implementation. Monthly review of the exception list.       |
| S6 | IT selects vendors, carries out the security review and completes the procurement sign-off on its own. | Vendor decisions may focus more on cost or speed, while important security requirements or contract protections are missed. | IT, CISO, Legal, Finance, BU Leader | The Business Unit and IT define the need, CISO carries out the security review, Legal reviews the contract and Finance checks the financial side. High-value or high-risk purchases are approved by the appropriate executive authority. A simpler checklist can be used for low-risk vendors. | Low when a tiered review is used. Review every six months.                       |

The main approach is to use tiered controls. Higher-risk activities receive more detailed review, while lower-risk activities can use simpler checks. This keeps the process practical while still making sure that important decisions are not approved by the same person who carried out the work. This supports the separation of duties expected in security governance.

## **6.2 Decision Recording and Assurance Note**

TechGlobal should keep a clear and auditable record of significant security decisions, including strategy and policy decisions, risk acceptance, exceptions, incident escalations and vendor approvals. Each decision should be entered in the central Decision Log maintained by the CISO office within 5 business days.

The log should include the date, issue, decision owner, decision taken, reason for the decision, related risk ID, supporting evidence, action owner, due date and review date. Where a risk is accepted, the record should also show who accepted it and the authority under which it was accepted. Supporting documents such as risk assessments, approval forms and legal notes should be linked by ID and stored in a read-only folder with version control.

Each action should have a named owner and due date. The CISO office should track overdue actions and include their status in the Steering Committee pack. An action should only be marked as complete when there is evidence, such as a patch report, configuration record, training record or vendor confirmation. CRO / Risk should independently verify risk closures.

The Steering Committee should review the decision log monthly, while the Executive Security Council should review high and material decisions quarterly. Internal Audit, when in place, can provide independent assurance by sampling decisions and reporting its findings to the Board. This supports the Three Lines Model, where Internal Audit provides independent assurance to the governing body. [IIA, 2020]

A decision should only be closed when the required actions have been completed and the risk score has been updated. Accepted risks should have a review date, with a maximum review period of 12 months. Security exceptions should normally be reviewed within 90 days. If an action or treatment is delayed, the owner should request an extension and obtain approval at the same or higher level instead of allowing the deadline to pass without a record.

For urgent situations, verbal or emergency approvals can still be used, but they should be written into the Decision Log within 24 hours. This allows TechGlobal to respond quickly while still keeping a proper record of what happened, who made the decision, why it was made and how the issue was eventually closed.

This approach supports the governance principles in ISO/IEC 27014, particularly evaluating, directing, monitoring and communicating information security processes. It also supports NIST CSF 2.0's focus on governance, roles, policies and oversight.

## **Conclusion**

In this lab, I learnt that TechGlobal's main governance problem is not just about having the right security technology. It is also about having clear roles, accountability and proper escalation. The proposed structure gives the Board oversight, the CEO executive accountability, the CISO

responsibility for security leadership, CRO / Risk an independent risk role, and IT a clear focus on secure delivery.

The committee structure provides a proper place for cross-functional security decisions, while the RACI matrix makes it clear who is responsible and accountable for each activity. The three-level escalation process also helps ensure that smaller issues are handled at the operational level while serious risks are escalated to the right level. The segregation of duties controls reduce the risk of one person or function controlling a decision from beginning to end.

As a student, my main lesson from this lab is that security governance is about people and decisions as much as it is about technology. When roles are clearly defined, decisions are properly recorded and risks are escalated through the right channels, security becomes a shared responsibility that can be followed and reviewed. I believe the proposed model is practical for TechGlobal because it works with existing roles and uses regular meetings, simple templates and clear processes without creating unnecessary bureaucracy.

## References

Pascoe, C., Quinn, S. and Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology, NIST CSWP 29.

International Organization for Standardization. (2020). *ISO/IEC 27014:2020 Information security, cybersecurity and privacy protection: Governance of information security*. Geneva: ISO.

International Cybersecurity and Digital Forensics Academy (ICDFA). (2026). *Roles and Responsibilities in Security Governance: Ensuring Effective Information Security*. GRC102 Week 3 lesson slides.

ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg: ISACA.

The Institute of Internal Auditors (IIA). (2020). *The IIA's Three Lines Model: An update of the Three Lines of Defense*. Lake Mary: IIA.